actual request, “Preflight” means it can be sent only in response to a preflight request, and “Both” means it can be sent on either.

Table 5.1 CORS response headers

CORS header	Response	Description
`Access-Control-Allow-Origin`	Both	Specifies a single origin that should be allowed access, or else the wildcard * that allows access from any origin.
`Access-Control-Allow-Headers`	Preflight	Lists the non-simple headers that can be included on cross-origin requests to this server. The wildcard value * can be used to allow any headers.
`Access-Control-Allow-Methods`	Preflight	Lists the HTTP methods that are allowed, or the wildcard * to allow any method.
`Access-Control-Allow-Credentials`	Both	Indicates whether the browser should include credentials on the request. Credentials in this case means browser cookies, saved HTTP Basic/Digest passwords, and TLS client certificates. If set to `true`, then none of the other headers can use a wildcard value.
`Access-Control-Max-Age`	Preflight	Indicates the maximum number of seconds that the browser should cache this CORS response. Browsers typically impose a hard-coded upper limit on this value of around 24 hours or less (Chrome currently limits this to just 10 minutes). This only applies to the allowed headers and allowed methods.
`Access-Control-Expose-Headers`	Actual	Only a small set of basic headers are exposed from the response to a cross-origin request by default. Use this header to expose any non-standard headers that your API returns in responses.

TIP If you return a specific allowed origin in the `Access-Control-Allow-Origin` response header, then you should also include a `Vary: Origin` header to ensure the